

SECURITY ASSESSMENT REPORT

shiroine.web.id

TARGET	shiroine.web.id
DATE	2026-07-19
TEAM	XC-HACK · Hacking XC Hub
TYPE	Black-Box Penetration Test
SEVERITY	CRITICAL — Immediate Action Required
FINDINGS	7 total 2 Critical · 3 High · 2 Medium

This report documents vulnerabilities discovered during an authorized security assessment of **shiroine.web.id**. Findings are classified by severity with detailed impact scenarios and actionable remediation guidance.

CONFIDENTIAL — For authorized personnel only. Do not distribute without permission.

01 EXECUTIVE SUMMARY

Pengujian black-box terhadap **shiroine.web.id** mengungkap **7 kerentanan aktif** yang memungkinkan attacker melakukan price manipulation, authentication bypass, dan eksfiltrasi data sensitif sistem — tanpa memerlukan kredensial valid. Dua kerentanan Critical berdampak langsung pada integritas finansial dan keamanan akses sistem.

Severity	Count	Risk Level
CRITICAL	2	Immediate patch required
HIGH	3	Patch within 7 days
MEDIUM	2	Patch within 30 days
TOTAL	7	—

Overall Risk Score

Berdasarkan scoring CVSS v3.1 dan dampak bisnis, overall risk score sistem ini adalah:

9.1 / 10

CRITICAL RISK

Sistem saat ini dalam kondisi dapat dikompromikan secara penuh oleh attacker tanpa autentikasi. Patch segera pada F-01 dan F-06 diprioritaskan.

02 ATTACK CHAIN

Rangkaian eksploitasi yang dapat dieksekusi oleh attacker tanpa kredensial apapun:

STEP 1 Initial Recon

```
curl https://shiroine.web.id/api/health → Discover: Midtrans SANDBOX mode active, version info exposed
```

STEP 2 Auth Bypass (F-06)

```
curl -H "Authorization: Bearer null" https://shiroine.web.id/api/admin/users → 200 OK – bypass auth, akses endpoint proteksi
```

STEP 3 Data Exfil (F-07)

```
→ Dump owner list + nomor WhatsApp → Lihat statistik internal: 296.884+ pesan, traffic chart
```

STEP 4 Price Manipulation (F-01)

```
curl -X POST https://shiroine.web.id/api/payment/create-transaction \ -d '{"package":"premium","amount":1}' → 200 OK – transaksi Rp1 untuk paket Premium berhasil
```

STEP 5 Webhook Forge (F-03)

```
→ 10 char pertama signature hash bocor dari error message → Attacker dapat brute-force sisa hash  
→ forge webhook payment success
```

STEP 6 Server Key Extraction (F-02)

```
→ Prefix + panjang Midtrans server key terekspose di diagnostic → Digunakan untuk forge webhook & direct Midtrans API abuse
```

Total Waktu Eksekusi: ~12 menit dari zero knowledge ke full compromise.

03 FINDINGS DETAIL

CRITICAL

[F-01]

Unauthenticated Price Manipulation

Deskripsi

Endpoint `/api/payment/create-transaction` tidak memerlukan autentikasi dan menerima parameter **amount** langsung dari request body klien tanpa validasi sisi-server. Server memproses nilai harga apapun yang dikirimkan client.

CVSS Score

9.8 (Critical) — AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Proof of Concept

```
curl -X POST https://shiroine.web.id/api/payment/create-transaction \ -H "Content-Type: application/json" \ -d '{"package": "premium_annual", "amount": 1, "currency": "IDR"}' # Response: 200 OK - Transaction created, amount: Rp 1
```

Skenario Dampak

- Attacker membeli paket Premium/Annual seharga Rp 1 — kerugian finansial langsung per transaksi.
- Abuse massal: bot otomatis membuat ratusan transaksi Rp 1, menguras stok lisensi premium.
- Reputasi platform rusak: user legitimate bisa claim layanan premium secara gratis.
- Midtrans sandbox mode aktif memperparah: transaksi fake tidak terdeteksi sebagai anomali.
- Potential chargeback fraud: attacker dapat order Rp 1, lalu klaim refund via bank.

Solusi & Remediasi

- [IMMEDIATE] Pindahkan validasi harga ke server-side — ambil harga dari database berdasarkan package_id, JANGAN dari request body.
- [IMMEDIATE] Tambahkan autentikasi wajib di endpoint create-transaction.
- Implementasi rate limiting: maks 3 transaksi per IP per jam.
- Verifikasi amount di webhook Midtrans sebelum aktivasi layanan.
- Switch Midtrans ke production mode — sandbox tidak boleh live di production.
- Audit log semua transaksi dengan anomaly detection untuk harga di luar range normal.

CRITICAL

[F-06]

Broken Authentication — Bearer null Bypass

Deskripsi

Server melakukan validasi autentikasi dengan memeriksa **keberadaan** header **Authorization**, bukan **validitas** nilai token. Mengirimkan `Authorization: Bearer null` atau `Authorization: Bearer undefined` berhasil membypass auth check dan mengakses endpoint yang seharusnya terproteksi.

CVSS Score

9.1 (Critical) — AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Proof of Concept

```
# Normal request - 401 Unauthorized curl https://shiroine.web.id/api/admin/users # Bypass - 200 OK curl -H "Authorization: Bearer null" https://shiroine.web.id/api/admin/users # Response: {"owners": [...], "stats": {...}}
```

Skenario Dampak

- Akses penuh ke semua endpoint admin tanpa password — zero credential required.
- Kombinasi dengan F-07: dump seluruh daftar owner + nomor WhatsApp dalam satu request.
- Attacker dapat modify/delete data internal jika endpoint write juga menggunakan auth check yang sama.
- Statistik bot internal terekspos: traffic pattern, user count, message volume — intelligence untuk targeted attack.
- Dapat digunakan sebagai pivot: akses admin endpoint → temukan endpoint sensitif lain.

Root Cause Analysis

Bug tipikal pada middleware autentikasi yang menggunakan pola:

```
if (req.headers.authorization) { /* trust it */ }
```

alih-alih memvalidasi token secara kriptografis.

Solusi & Remediasi

- **[IMMEDIATE]** Validasi token secara kriptografis — verify signature JWT atau lookup token di database.
- **[IMMEDIATE]** Tolak semua nilai token yang bukan valid JWT: null, undefined, empty string, whitespace.
- Implementasi middleware terpusat: satu auth function yang digunakan semua endpoint — hindari auth check tersebar.
- Unit test wajib untuk auth bypass: test dengan Bearer null, Bearer undefined, Bearer "", dll.
- Implementasi token blacklist untuk revokasi token yang dicurigai.
- Log semua failed auth attempts dengan IP dan User-Agent untuk deteksi abuse.

03 FINDINGS DETAIL (cont.)

HIGH

[F-02]

Server Key Metadata Leaked in Error Response

Deskripsi

Error response dari server menyertakan informasi diagnostik yang mengungkap **prefix dan panjang** Midtrans server key. Informasi ini dapat digunakan untuk mempersempit ruang brute-force key.

CVSS Score

7.5 (High) — AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Skenario Dampak

- Prefix key + panjang → mempersempit keyspace brute-force dari 10^{40} menjadi lebih manageable.
- Kombinasi dengan F-03 (signature hash leak): attacker dapat forge webhook Midtrans.
- Akses Midtrans API langsung dengan server key → manipulasi status transaksi di dashboard merchant.
- Refund fraud: approve refund untuk transaksi yang tidak pernah dibayar.

Solusi & Remediasi

- **[URGENT]** Rotate Midtrans server key segera — key yang sudah terekspos metadata-nya harus dianggap compromised.
- Strip semua informasi sensitif dari error response di production — gunakan generic error messages.
- Implementasi error handling terpusat yang memfilter stack trace dan diagnostic info.
- Simpan server key di environment variable / secret manager, bukan hardcode di config file.
- Aktifkan Midtrans IP whitelist: hanya server IP yang boleh call Midtrans API.

HIGH

[F-03]

Webhook Signature Hash Partially Leaked

Deskripsi

Error message pada webhook endpoint menyertakan **10 karakter pertama** dari expected HMAC-SHA512 signature. Ini memberikan oracle yang dapat digunakan untuk memverifikasi upaya forging.

CVSS Score

7.2 (High) — AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

Skenario Dampak

- Signature oracle: attacker mengirim webhook palsu berulang kali, bandingkan 10 char pertama → validasi prefix secara incremental.
- Kombinasi F-02 + F-03: dengan prefix key + partial hash → forge full webhook signature.
- Inject fake payment notification: mark transaksi sebagai 'paid' tanpa pembayaran nyata.
- Mass account upgrade: seluruh user base diupgrade ke premium gratis melalui forged webhook.

Solusi & Remediasi

- **[URGENT]** Hapus semua informasi signature dari error response — cukup return HTTP 400 tanpa detail.
- Implementasi constant-time comparison untuk signature verification — hindari timing oracle.
- Whitelist IP Midtrans di level firewall/nginx untuk webhook endpoint.
- Log dan alert semua webhook dengan signature invalid — ini indikasi probe oleh attacker.
- Implementasi replay attack prevention: reject webhook dengan timestamp lebih dari 5 menit.

HIGH

[F-07]

Sensitive Data Exposure via Auth Bypass

Deskripsi

Melalui F-06 (Bearer null bypass), attacker dapat mengakses endpoint admin yang mengembalikan data sensitif: **daftar owner & sub-owner** beserta nomor WhatsApp, serta **statistik internal bot** (296.884+ pesan, traffic pattern).

CVSS Score

7.5 (High) — AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N

Skenario Dampak

- Nomor WhatsApp owner/sub-owner terekspos → targeted phishing, SIM swap attack, social engineering.
- Traffic pattern internal → attacker mengetahui jam sibuk sistem untuk timing serangan.
- Jumlah pengguna aktif (296k+ pesan) → mengestimasi revenue dan nilai target untuk extortion.
- Sub-owner list → identify semua akun privileged untuk targeted credential stuffing.
- Potensi GDPR/UU PDP violation: data pribadi terekspos tanpa consent.

Solusi & Remediasi

- **[IMMEDIATE]** Fix F-06 terlebih dahulu — ini prerequisite untuk F-07.
- Implement data minimization: admin endpoint hanya return data yang dibutuhkan, bukan full record.
- Mask nomor WhatsApp di response: tampilkan hanya 4 digit terakhir.
- Pisahkan endpoint statistik internal dari endpoint admin user — gunakan auth level berbeda.
- Audit semua endpoint admin untuk data yang tidak perlu dikembalikan.

03 FINDINGS DETAIL — Medium

MEDIUM

[F-04]

Midtrans Sandbox Mode Active on Production

Deskripsi

Health endpoint publik mengkonfirmasi payment gateway berjalan di sandbox mode di environment production. Ini mengindikasikan konfigurasi yang belum selesai dan memungkinkan transaksi test melewati sistem tanpa deteksi.

CVSS Score

5.3 (Medium)

Skenario Dampak

- Transaksi test (fake) dapat diproses tanpa uang nyata berpindah tangan.
- Sandbox webhook tidak memiliki proteksi yang sama dengan production — mudah di-forge.
- Attacker F-01 diperparah: tidak ada fraud detection Midtrans di sandbox mode.
- Potensi confusion antara test data dan production data di dashboard merchant.

Solusi & Remediasi

- [URGENT] Switch ke Midtrans production key segera setelah rotate (lihat F-02).
- Implementasi environment check: aplikasi harus crash/refuse start jika prod env tapi sandbox key.
- Audit semua transaksi yang terjadi selama sandbox mode aktif.
- Implementasi CI/CD check: deployment ke production wajib fail jika MIDTRANS_ENV != 'production'.

MEDIUM

[F-05]

Success Page Client-Side Only — No Server Verification

Deskripsi

Halaman sukses pembayaran dapat diakses langsung via URL tanpa server melakukan verifikasi apakah transaksi benar-benar selesai. Client-side check saja tidak cukup sebagai gatekeeper.

CVSS Score

5.0 (Medium)

Skenario Dampak

- User dapat mengakses success page dan mengklaim 'sudah bayar' padahal belum.
- Jika aktivasi layanan dipicu oleh akses success page (bukan webhook), ini bypass payment.
- Social engineering: screenshot success page palsu untuk klaim refund atau dispute.
- Crawler/bot dapat trigger aktivasi massal dengan hit success page URL.

Solusi & Remediasi

- Pindahkan semua logika aktivasi layanan ke webhook Midtrans — bukan client success redirect.
- Success page harus query server untuk verifikasi status transaksi sebelum menampilkan konten.
- Implementasi one-time token pada success URL yang expire setelah 15 menit.
- Jangan pernah trust client-side untuk keputusan bisnis (aktivasi, upgrade, pembayaran).

04 REMEDIATION ROADMAP

Prioritas perbaikan berdasarkan severity dan ease of exploitation:

Priority	Finding	Action	Timeline
P0 — NOW	F-06	Fix auth middleware — validate token properly	< 24 jam
P0 — NOW	F-01	Server-side price validation	< 24 jam
P1 — ASAP	F-02	Rotate Midtrans key + strip diagnostic errors	< 48 jam
P1 — ASAP	F-03	Remove hash from webhook error + IP whitelist	< 48 jam
P1 — ASAP	F-04	Switch Midtrans production mode	< 48 jam
P2 — WEEK	F-07	Data minimization + mask PII	< 7 hari
P3 — MONTH	F-05	Server-side success verification	< 30 hari

Quick Wins (dapat dilakukan dalam 1 jam)

1. Tambahkan validasi if (!token || token === 'null' || token === 'undefined') return 401; di auth middleware.
2. Pindahkan harga dari request body ke server lookup: const price = PACKAGES[req.body.package_id].price;
3. Set NODE_ENV=production + Midtrans production key.
4. Strip error diagnostic: ganti semua res.json({error, diagnostic}) dengan res.json({error: 'Bad request'})

05 CONCLUSION

Sistem **shiroine.web.id** dalam kondisi kritis dan dapat dikompromikan penuh oleh attacker dengan skill dasar dalam waktu kurang dari 15 menit. Dua kerentanan Critical (F-01 dan F-06) harus diperbaiki dalam waktu 24 jam. Kegagalan memperbaiki dalam timeframe ini berpotensi menyebabkan:

- Kerugian finansial langsung dari price manipulation yang dapat diotomasi.
- Eksfiltrasi data personal owner/sub-owner (potensi pelanggaran UU PDP Indonesia).
- Kompromi payment infrastructure melalui server key + webhook forging.
- Reputasi platform rusak jika eksploitasi menjadi publik.

Report ini disusun oleh **XC-HACK · Hacking XC Hub** pada 2026-07-19 sebagai bagian dari authorized security assessment. Semua temuan telah diverifikasi secara manual dengan proof-of-concept. Disclosure dilakukan secara responsible.

XC-HACK · Hacking XC Hub · pointrungkat-art · 2026